

Before to start the script at the first time, you need to install the "**binutils**" package on the current server.

```
sudo apt-get install binutils -y
```

Requirements

R1 : Only version 2 of the SSH protocol shall be authorized.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Add the following command :

```
Protocol 2
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R2 : SSH shall be used instead of historical protocols (TELNET, RSH, RLOGIN) for remote shell access.

- Install the "**openssh-server**" package.

```
sudo apt-get install openssh-server -y
```

- Start the "**sshd**" service.

```
sudo systemctl start sshd
```

- Enable the "**sshd**" service.

```
sudo systemctl enable sshd
```

R3 : TELNET, RSH and RLOGIN remote access servers shall be uninstalled from the system.

- Remove the **TELNET**, **RSH** and **RLOGIN** packages on the server.

```
sudo apt-get remove --purge -y telnetd inetutils-telnetd inetutils-telnet  
rsh-server rsh-client rsh-redone-client rsh-redone-server
```

R4 : SCP or SFTP shall be used instead of historical protocols (RCP, FTP) for file transfers.

- Check if the **RCP** or the **FTP** service is used on the serveur.

```
dpkg -l | awk '{print $2}' | grep -qi "vsftpd"  
dpkg -l | awk '{print $2}' | grep -qi "proftpd"  
dpkg -l | awk '{print $2}' | grep -qi "pure-ftpd"  
dpkg -l | awk '{print $2}' | grep -qi "inetutils-ftpd"  
dpkg -l | awk '{print $2}' | grep -qi "tftpd"  
dpkg -l | awk '{print $2}' | grep -qi "inetutils-ftp"  
dpkg -l | awk '{print $2}' | grep -qi "rsh-client"  
dpkg -l | awk '{print $2}' | grep -qi "rsh-redone-client"
```

- If one of these service is installed, migrate on a SCP or a SFTP service.

R5 : The implementation of SSH tunnels shall only be applied to protocols that do not provide robust security mechanisms and that can benefit from it (for example: X11, VNC). This recommendation does not exempt from using additional low level security protocols, such as IPsec.

- Edit the "sshd_config" file.

```
sudo nano /etc/ssh/sshd_config
```

- Search these three parameters and change the values as follows (or uncomment):

```
PermitTunnel no  
AllowTcpForwarding no  
X11Forwarding no
```

- Restart the "sshd" service.

```
sudo systemctl restart sshd
```

R6 : The server authenticity shall always be checked prior to access. This is achieved through preliminary machine

authentication by checking the server public key fingerprint, or by verifying the server certificate.

- Edit the "**ssh_config**" file.

```
sudo nano /etc/ssh/ssh_config
```

- Uncomment this parameter :

```
StrictHostKeyChecking ask
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R7 : The use of DSA keys is not recommended.

- Search on the server if one or more **DSA** keys existing.

```
sudo find / -type f -name "*id_dsa*" -print 2>/dev/null  
sudo find / -type f -name "*ssh_host_dsa_key*" -print 2>/dev/null
```

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- If the parameter "**HostKey /etc/ssh/ssh_host_dsa_key**" is present and uncomment, comment it (if not present, dont add it) :

```
#HostKey /etc/ssh/ssh_host_rsa_key
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R8 : The minimum key size shall be 2048 bits for RSA.

- Edit the "**ssh_config**" file.

```
sudo nano /etc/ssh/ssh_config
```

- Add the following parameter in the "*HostKey*" part :

```
RequiredRSASize 2048
```

- *This parameter required Open-SSH 9.2 version minimum !*
- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R9 : The minimum key size shall be 256 bits for ECDSA.

R10 : ECDSA keys should be favoured over RSA keys when supported by SSH clients and servers.

- Search on the server if one or more **RSA** keys existing.

```
sudo find / -type f -name "*id_rsa*" -print 2>/dev/null
```

- If the command return something, generate a new SSH key with the *ed25519* algorithm and remove the RSA keys.

R11 : Keys should be generated in a context where the RNG is reliable, or at least in an environment where enough entropy has been accumulated.

R12 : Some rules can ensure that the entropy pool is properly filled (keys must be generated on a physical equipment, system must have several independent sources of entropy, key generation shall occur only after a long period of activity (several minutes or even hours))

R13 : The private key should only be known by the entity who needs to prove its identity to a third party and possibly to a trusted authority. This private key should be properly protected in order to avoid its disclosure to any unauthorized person.

- Check if all of the SSH private keys files on the server have **600** as permission.

```
sudo stat -c "%a" /etc/ssh/ssh_host_ed25519_key  
sudo stat -c "%a" /etc/ssh/ssh_host_ecdsa_key
```

```
sudo stat -c "%a" /etc/ssh/ssh_host_rsa_key
```

- If the permission are different, apply the correct permission :

```
sudo chmod 600 /etc/ssh/ssh_host_ed25519_key
```

R14 : Private keys shall be password protected using AES128-CBC mode.

- Edit the "sshd_config" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter :

```
StrictModes yes
```

- Restart the "sshd" service.

```
sudo systemctl restart sshd
```

R15 : The encryption algorithm shall either be AES128-CTR, AES192-CTR or AES256-CTR. The integrity mechanism shall rely on HMAC-SHA1, HMAC-SHA256 or HMACSHA512.

- Edit the "ssh_config" file.

```
sudo nano /etc/ssh/ssh_config
```

- Uncomment these parameters and adjust the value as follow :

```
Ciphers aes128-ctr,aes192-ctr,aes256-ctr  
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com
```

- Edit the "sshd_config" file.

```
sudo nano /etc/ssh/sshd_config
```

- Add the following parameters in the "Ciphers and keying" part :

```
Ciphers aes128-ctr,aes192-ctr,aes256-ctr
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R16 : A preliminary step in hardening the sshd service is to use proper compilation flags.

R17 : User authentication should be performed with one of the following mechanisms, given by order of preference (ECDSA asymmetric cryptography, RSA asymmetric cryptography, symmetric cryptography (Kerberos tickets from the GSSAPI), authentication modules that expose neither the user password nor its hash (third-party PAM or BSD Auth modules), password check against a database (such as passwd/shadow) or a directory)

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment these parameters :

```
PubkeyAuthentication yes
GSSAPIAuthentication yes
GSSAPICleanupCredentials yes
UsePAM yes
PasswordAuthentication yes
```

- Add the following parameters in the "*Ciphers and keying*" part :

```
HostKeyAlgorithms ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,rsa-sha2-512,rsa-sha2-256
PubkeyAcceptedAlgorithms ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,rsa-sha2-512,rsa-sha2-256
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

- Install the "**krb5-user**" and the "**libpam-krb5**" packages on the server.

```
sudo apt-get install krb5-user libpam-krb5 -y
```

R18 : Users rights shall follow the least privilege principle. Restrictions can be applied on several parameters: available commands, source IP, redirection of forwarding permissions. . .

R19 : When SSH bouncing is necessary through a relay host, Agent Forwarding (-A option of ssh) should be used.

As default, the agent forwarding is disable.

Disable the agent forwarding

- Edit the "**ssh_config**" file.

```
sudo nano /etc/ssh/ssh_config
```

- Uncomment this parameter and adjust the value as follow :

```
ForwardAgent no
```

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
AllowAgentForwarding no
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

Enable the agent forwarding

- On the client server :
 - Edit the "**~/.ssh/config**" file.
 - Add these lines and adjuste with your configuration :

```
Host bastion
    HostName bastion.example.com
    User admin
    ForwardAgent yes

Host server-final
    HostName 10.0.2.12
    User admin
    ProxyJump bastion
    ForwardAgent yes

AllowAgentForwarding no
```

- On the server :
 - Edit the `"/etc/ssh/sshd_config"` file.
 - Add this line and adjuste with your configuration :

```
AllowAgentForwarding yes
```

- Restart the `"sshd"` service when your configuration is implement

R20 : The relay host server shall be a trusted host.

R21 : Every user must have his own, unique, non-transferable account.

- Edit the `"sshd_config"` file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
PermitRootLogin no
```

- Restart the `"sshd"` service.

```
sudo systemctl restart sshd
```

R22 : Access to a service shall be restricted to users having a legitimate need. This restriction shall apply on a white-list basis: only explicitly allowed users shall connect to a host via SSH and possibly from specified source IP addresses.

- Edit the "sshd_config" file.

```
sudo nano /etc/ssh/sshd_config
```

- Add the following command and adjust the value with your needs :

```
AllowUsers example@10.10.10.1
```

- Restart the "sshd" service.

```
sudo systemctl restart sshd
```

R23 : The ability for a user to tamper with the environment shall be denied by default. Usersupplied environment variables shall be selected on a case-by-case basis.

- Edit the "sshd_config" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
PermitUserEnvironment no
```

- Restart the "sshd" service.

```
sudo systemctl restart sshd
```

R24 : Users shall only execute strictly necessary commands. This restriction can be achieved in the following ways : using the ForceCommand directive on a per user basis in the sshd_config file, specifying some options in the authorized_keys file (See 4.3.1), using secure binaries such as sudo or su.

R25 : The SSH server shall only listen on the administration network.

- Edit the "sshd_config" file.

```
sudo nano /etc/ssh/sshd_config
```

- Add the following command and adjust the value with your needs :

```
ListenAddress 192.168.1.1
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R26 : When the SSH server is exposed to an uncontrolled network, one should change its listening port (22). Preference should be given to privileged ports (below 1024).

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
Port 26
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R27 : Except for duly justified needs, any flow forwarding feature shall be turned off : in the SSH server configuration, in the local firewall by blocking connections.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
AllowTcpForwarding no
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R28 : X11 forwarding shall be disabled on the server.

- Edit the "**ssh_config**" file.

```
sudo nano /etc/ssh/ssh_config
```

- Uncomment this parameter and adjust the value as follow :

```
ForwardX11Trusted no
```

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
X11Forwarding no
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R29 : It is recommended to create distinct CAs when their roles differ. There will be, for example : one CA for the “hosts” CA role, one CA for the “users” CA role. Each CA private key shall be protected by a unique and robust password.

R30 : If a key cannot be considered safe anymore, it shall be quickly revoked at the SSH level.

- Create a file with the name "**revoked_keys**".

```
sudo touch /etc/ssh/revoked_keys
```

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Add the following command :

```
RevokedKeys /etc/ssh/revoked_keys
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

R31 : SSH host key fingerprints obtained through DNS records should not be trusted without complimentary verifications.

- Edit the "**ssh_config**" file.

```
sudo nano /etc/ssh/ssh_config
```

- Add the following command :

```
VerifyHostKeyDNS ask
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

Personnal Requirements

P1 : The lifetime of SSH keys must be a maximum of 3 years.

P2 : Access to the user's private key must be done only with the user account in question.

- Apply the correct permission on the user's private key folders and files.

```
sudo chmod 600 /root/.ssh/id_*  
sudo chmod 600 /home/*/.*ssh/id_*
```

P3 : Generate a passphrase for all user keys.

- Check if the current SSH keys generated are a passphrase.

```
sudo ssh-keygen -y -f "/home/*.ssh/id_*.pub"
sudo ssh-keygen -y -f "/root/.ssh/id_*.pub"
```

- If any password is present on the present SSH keys, please generate a new SSH key with the "ed25519" algorithm and a passphrase.

P4 : Limit access to the .ssh folder.

- Apply the correct permission on the user's private key folders and files.

```
sudo chmod 700 /root/.ssh
sudo chmod 700 /home/*.ssh
```

P5 : Implement the separation of privileges.

- Edit the "sshd_config" file.

```
sudo nano /etc/ssh/sshd_config
```

- Add the following command :

```
UsePrivilegeSeparation sandbox
```

- Restart the "sshd" service.

```
sudo systemctl restart sshd
```

P6 : Implement the principle of least privilege for users using SFTP only.

Installation

- Edit the "sshd_config" file.

```
sudo nano /etc/ssh/sshd_config
```

- Add the following commands at the end of the file :

```
Subsystem sftp internal-sftp
Match Group sftp-users
    ChrootDirectory /sftp-home/%u
    ForceCommand internal-sftp
```

```
AllowTCPForwarding no
X11Forwarding no
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

- Create the "**sftp-users**" group.

```
sudo addgroup sftp-users
```

- Create a main directory for the SFTP home user directory and setup a permissions

```
sudo mkdir -p /sftp-home
sudo chown root:root /sftp-home
sudo chmod 755 /sftp-home
```

Configuration

- Create user folder :

```
sudo mkdir chown /sftp-home/user1
```

- Apply the permissions on the folder.

```
sudo chown root:root /sftp-home/user1
```

- Create folder and add the permissions on the folder where the user has the possibility to modify content.

```
mkdir /sftp-home/user1/uploads
chown user1:sftp-users /sftp-home/user1/uploads
chmod 750 /sftp-home/user1/uploads
```

P7 : Do not use a password for privileged accounts.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
PasswordAuthentication yes
```

- Add the following commands at the end of the file :

```
Match User root
    PasswordAuthentication no
    PubkeyAuthentication yes
```

```
Match Group sudo
    PasswordAuthentication no
    PubkeyAuthentication yes
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

P8 : Do not use the PAM module 'pam_krb5'.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
KerberosAuthentication no
GSSAPIAuthentication yes
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

- Edit the "**/etc/pam.d/sshd**" file.

```
sudo nano /etc/pam.d/sshd
```

- If an entry with "**pam_krb5**" is present in the file, remove it.

P9 : Disable login without password.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
PermitEmptyPasswords no
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

P10 : Define a time period for the authentication operation.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
LoginGraceTime 30
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

P11 : Limit the number of connection attempts.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
MaxAuthTries 2
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

P12 : Disable the root connection in SSH.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```


- Uncomment this parameter and adjust the value as follow :

```
PermitRootLogin no
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

P13 : Display information related to the user's last login.

- Edit the "**sshd_config**" file.

```
sudo nano /etc/ssh/sshd_config
```

- Uncomment this parameter and adjust the value as follow :

```
PrintLastLog yes
```

- Restart the "**sshd**" service.

```
sudo systemctl restart sshd
```

P14 : Enable 2FA on SSH connection.